

ACCEPTABLE USE POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Acceptable Use Policy
Document ID	POL-AUP-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC1.1, CC1.4, CC1.5, CC2.2, CC6.1, CC6.7, CC6.8 and CC7.2, HIPAA Security Rule 45 CFR §164.310(b) and §164.312(a), and GDPR Articles 5, 6 and 13. It applies to the systems the Company actually runs — AWS, GitHub, Google Workspace and approved AI services — used mostly from personally owned laptops.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 WHAT GOOD USE LOOKS LIKE.....	6
6 PERSONAL USE AND PERSONAL DEVICES	7
7 USING AI TOOLS	7
8 SOFTWARE, SERVICES AND ACCESS	8
9 WHAT IS NOT ACCEPTABLE	8
10 MONITORING AND PRIVACY	8
11 ACKNOWLEDGEMENT.....	9
12 ENFORCEMENT.....	9
13 EXCEPTIONS.....	9
14 REFERENCE.....	9
1 DOCUMENT POLICY HISTORY	9

1 Overview and Purpose

PromptHalo Technologies (“the Company”) is a small, remote team. People work from their own laptops, in Google Workspace, AWS and GitHub, and use AI tools as part of ordinary work. This Policy says what good use of those systems looks like.

It is written to let people get on with the work. The rules here are the few that genuinely protect client information; everything else is left to judgement. Where a rule would slow the work without reducing risk, it is not in this Policy.

2 Scope

This Policy applies to everyone who uses Company systems — employees, officers, contractors, consultants, interns and temporary workers — and to any device they use for Company work, whether the Company provided it or not.

“Company systems” means Google Workspace, AWS, GitHub, the approved AI services, and any other account the Company pays for or holds data in. It does not mean a person's own device, which remains theirs.

Requirements apply so far as they are lawful where each person works, and the Company uses the least costly option that satisfies a requirement. Nothing here requires software to be installed on a personal device.

3 Roles and Definitions

1. “The Company” refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. Everyone is responsible for their own use of Company systems. Where someone is unsure whether something is acceptable, asking the Accountable Party first is always the right answer and is never held against them. [SOC 2: CC1.5, CC2.2]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Approved AI tool** — an artificial intelligence service reached through a Company account, on the register maintained under the AI Governance Policy.
3. **Client information** — any information obtained during an engagement, including findings, evidence, architecture, incident detail and personal data.

4. **Company systems** — Google Workspace, AWS, GitHub, approved AI services, and any other account the Company pays for or holds data in.
5. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
6. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
7. **Incidental personal use** — limited personal use of Company systems that does not interfere with work, cost the Company anything material, or put Company or client information at risk.
8. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. The Committee's composition is reviewed as the Company grows, and additional members are appointed when an oversight member independent of security operations becomes available. [SOC 2: CC1.2, CC1.3]
9. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
10. **Security Officer** — the individual accountable for day-to-day operation of the security program.
11. **Shadow IT** — a service adopted for Company work without being assessed and added to the inventory.

5 What Good Use Looks Like

Five things carry almost all the risk. If these hold, the rest is judgement.

1. Company and client work happens in Company accounts, not personal ones. Not personal email, not personal cloud storage, not a personal AI account. [SOC 2: CC6.7 · C1.1]
2. Client information stays in Google Workspace, AWS and GitHub rather than on anyone's laptop. Where a local copy is needed to do the work, it is deleted when it is no longer needed. [SOC 2: CC6.7, CC6.5]
3. Credentials are not shared, not reused from personal accounts, and not put in code, tickets or chat. Where a secret must be shared, it goes through the password manager. [SOC 2: CC6.1, CC6.7]
4. Multi-factor authentication stays on, and people sign in through the Company identity provider rather than creating separate logins. [SOC 2: CC6.1]
5. Anything that looks wrong — a suspicious message, a mistaken send, an account behaving oddly — is reported to the Accountable Party the same day. Reporting a mistake promptly is treated as doing the right thing, not as the mistake. [SOC 2: CC2.2, CC7.3]

6 Personal Use and Personal Devices

People use their own laptops and phones, and the Company does not manage them. It protects information by controlling where the information sits and who can reach it, not by controlling the device.

1. Incidental personal use of Company systems is fine. Personal use that costs the Company money, interferes with the work, or puts client information at risk is not. [SOC 2: CC1.1]
2. On a personal device, keep the protections the operating system already offers switched on: such as, disk encryption, a screen lock, and automatic updates, as applicable. Nothing needs to be installed, and the Company does not inspect the device. [SOC 2: CC6.8, CC6.4]
3. Company work is not done in a shared profile, and Company accounts are not signed into on someone else's device. [SOC 2: CC6.1]
4. Information classified Restricted is handled only on equipment the Company provides. If a role needs that, the Company provides the equipment. [SOC 2: CC6.1, CC6.4]
5. Report a lost or stolen device, or a password that may have been exposed, within a day. The Company signs the accounts out and resets credentials; it does not wipe personal devices. [SOC 2: CC7.4]

7 Using AI Tools

AI tools are part of how the work gets done here, and this Policy is written to keep them usable rather than to discourage them.

1. Use AI tools through Company accounts. Do not put Company or client information into free or consumer tiers, where the terms usually allow the provider to train on what is submitted. [SOC 2: CC6.7 • C1.1]
2. Which tools are approved, and what classification of information each may receive, is maintained under the AI Governance Policy. This Policy does not keep a second list. [SOC 2: CC1.1, CC9.2]
3. Adding a genuinely useful tool is encouraged; adding it without saying so is not. Ask the Accountable Party and it can usually be assessed the same week. [SOC 2: CC9.2, CC2.1]
4. A named person stays accountable for anything an AI tool produces that the Company relies on. Do not present AI output as verified unless you verified it. [SOC 2: CC1.1]
5. Where an agent or automation acts on Company systems, it runs under its own identity with only the access it needs, and a named person owns it. Ownership passes to someone else before that person's access is removed. [SOC 2: CC6.1, CC1.3]

8 Software, Services and Access

1. Connecting a third-party application to Google Workspace or GitHub requires approval, because a connected app inherits the access of the person who connected it. The allow-list is maintained under the Asset Management Policy. [SOC 2: CC6.8, CC9.2]
2. Use licensed, supported software for Company work. What is installed on a personal device otherwise is that person's business. [SOC 2: CC6.8]
3. Do not install anything that captures or forwards Company or client information — screen recorders, keyloggers, clipboard or browser-history syncing to a personal account. [SOC 2: CC6.8, CC6.7]
4. Production access in AWS, and administrative access in Google Workspace or GitHub, is granted only where a role needs it and is approved separately. [SOC 2: CC6.1, CC6.3]
5. Do not work around a control. If a control is stopping legitimate work, say so — that is a problem with the control, and it will be looked at. [SOC 2: CC1.1, CC5.3]

9 What Is Not Acceptable

The list is short on purpose. These are the things that cause real harm.

1. Accessing client information, you have no engagement reason to look at, or looking out of curiosity. [SOC 2: CC6.1 • C1.1]
2. Taking client information, credentials, assessment evidence or tooling output with you when an engagement ends. [SOC 2: CC6.5 • C1.2]
3. Using Company systems for anything unlawful, or for harassment, discrimination or intimidation. [SOC 2: CC1.1]
4. Testing, scanning or probing any system the Company has not been engaged to test. [SOC 2: CC1.1, CC6.1]
5. Sharing an account or letting someone else act under your identity. [SOC 2: CC6.1, CC6.2]

10 Monitoring and Privacy

The Company monitors its own systems and says here exactly what that means. Monitoring that is not disclosed is neither lawful nor trusted.

1. The Company logs authentication, administrative actions and access to its own systems — Google Workspace, AWS and GitHub — to protect Company and client information. [SOC 2: CC7.2 • GDPR Art. 6(1)(f), 13]
2. The Company does not monitor personal devices and collects nothing from them. It does not read personal email, browse history, or track location. [SOC 2: C1.1 • GDPR Art. 5(1)(c)]
3. Logs may be looked at for security reasons, not to measure how people spend their time. [SOC 2: CC7.2 • GDPR Art. 5(1)(b)]

4. Where monitoring reveals a possible policy breach, it is handled under the Code of Conduct, with the finding, the decision and the reason recorded. [SOC 2: CC1.1, CC1.5]

11 Acknowledgement

1. Everyone accepts this Policy when they join and once a year after that, in the same acknowledgment that covers the Code of Conduct. There is no separate form. [SOC 2: CC1.5, CC2.2, CC1.4]
2. The acknowledgment record shows the individual, the version accepted and the date and is reset when this Policy materially changes. [SOC 2: CC1.1, CC2.2]

12 Enforcement

1. A breach of this Policy is handled under the Code of Conduct: The Security Officer sets out the finding and recommends, the CEO decides and records the decision and the reason, and comparable cases are treated comparably. [SOC 2: CC1.1, CC1.5]
2. Reporting your own mistake early is treated as cooperation. Concealing one is the thing that attracts a consequence. [SOC 2: CC1.1]

13 Exceptions

Where a requirement of this Policy blocks legitimate work, an exception is recorded by the Accountable Party with the reason, the compensating measure and a review date, rather than being worked around silently. A line in the exception register is sufficient. Where no exceptions are in force, that is recorded affirmatively at the annual review.

14 Reference

1. SOC 2 Trust Services Criteria, Security category [CC1.1, CC1.4, CC1.5, CC2.2, CC6.1, CC6.7, CC6.8, CC7.2]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
3. POL-COC-001 Code of Conduct [SOC 2: CC1.1, CC1.5]
4. POL-AM-001 Asset Management Policy [SOC 2: CC6.8]
5. POL-AC-001 Access Control Policy [SOC 2: CC6.1, CC6.3]
6. POL-AI-001 Artificial Intelligence Governance Policy [SOC 2: CC9.2]
7. POL-DCL-001 Data Classification Policy [SOC 2: CC6.7]
8. POL-LOG-001 Logging and Monitoring Policy [SOC 2: CC7.2]
9. HIPAA Security Rule, 45 CFR §164.310(b) and §164.312(a)
10. EU General Data Protection Regulation, Articles 5, 6 and 13

1 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	August 18, 2026	Initial policy release

165